

정답

- ④ 인증

해설

- 정답** ③

④ 인증

해설

정답 ④

④ 기밀성

해설

- 정답** ①

5. 다음 중 정보에 대해 허락된 접근만 허용하고 그 외의 접근은 허용하지 않는 것을 의미하는 정보보호의 목표는?

- [illegible]

해설 ① 부인방지: 정보에 관여한 자가 이를 부인하지 못하도록 하는 것
 ③ 가용성: 허락된 자가 정보에 접근하고자 할 때 이것이 방해받지 않도록 하는 것
 ④ 무결성: 허락되지 않은 자가 정보를 임의로 수정할 수 없도록 하는 것

정답 ②

6. 2000년 초 야후, CNN, 아마존 등의 유명 웹사이트를 몇 시간 동안 접속 불가 상태로 빠뜨렸던 공격은?

- ① 모리스 웹 ② 랜섬웨어
③ 분산 서비스 거부 공격 ④ 에니그마

해설 2000년 초, 당시 접속자가 많았던 야후, CNN, 아마존 등의 웹사이트가 몇 시간 동안 접속이 불가능한 상태가 지속되었는데, 이는 공격자가 네트워크상에 있는 보안이 취약한 서버들을 찾아내어 미리 감염시킨 후 이 서버들이 정해진 시간에 위 웹사이트로 서비스 능력 이상의 수많은 패킷을 전송하는 분산 서비스 거부 공격 때문이다.

정답 ③

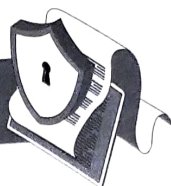
7. GDPR에 대한 설명으로 바른 것은?

- ① 우리나라의 ‘데이터 3법’
- ② 2016년에 제정된 유럽의 ‘개인정보 보호법’
- ③ 1974년에 제정된 미국의 ‘개인정보 보호법’
- ④ 해당 지역에 서비스를 제공하는 타 지역 기업은 적용받지 않는다.

해설 GDPR은 유럽에서 2016년에 제정하여 2018년부터 시행하고 있는 「개인정보 보호법」이다. GDPR은 EU에 서비스를 제공하는 전 세계 기업에 모두 적용된다.

정답 ②

연습문제



1. 암호와 관련된 다음 설명 중 바른 것은?

- ① 암호화된 메시지를 평문이라고 한다.
- ② 평문을 암호문으로 변환하는 것을 복호화라고 한다.
- ③ 암호문을 평문으로 변환하는 것을 암호화라고 한다.
- ④ 암호는 기밀성을 보장하기 위한 필수적인 기술이다.

해설 ① 암호화된 메시지를 암호문이라고 한다.
 ② 평문을 암호문으로 변환하는 것을 암호화라고 한다.
 ③ 암호문을 평문으로 변환하는 것을 복호화라고 한다.

정답 ④

2. 스테가노그래피(steganography)에 대해 설명하시오.

정답 및 해설 스테가노그래피는 실제로 전달하고자 하는 정보 자체를 숨기는 것이다. 과거에는 정보를 나무판에 새긴 후 밀랍을 발라 숨기기도 했으나, 오늘날에는 정보를 이미지 파일 등에 숨긴다.

3. 다음 중 스파르타의 봉 암호로 평문 'CRYPTOGRAPHY'를 암호화하여 만들 수 없는 암호문은?

- ① CYTGAHRPORPY ② CPGPRTRHYOAY
- ③ CTAROPYGHPRY ④ CYRHYPPATROG

해설 봉의 굵기가 ①은 한 바퀴에 두 글자를 적을 수 있는 경우, ②는 한 바퀴에 세 글자를 적을 수 있는 경우, ③은 한 바퀴에 네 글자를 적을 수 있는 경우에 평문 'CRYPTOGRAPHY'에 대한 암호문이다. ④는 문제의 평문으로는 만들 수 없고, 한 바퀴에 여섯 글자를 적을 수 있는 경우 평문 'CRYPTOYHPARG'에 대한 암호문이다.

정답 ④

4. 어떤 평문을 시프트 암호로 암호화하였더니 'LOPV'라는 암호문이 나왔다. 키가 1인 경우, 이 암호문을 복호화하는 과정과 함께 평문을 구하시오.

정답 및 해설 시프트 암호는 키 k 에 대해 각 문자를 알파벳 순서로 k 번째 뒤 문자로 치환하는 암호화 방법으로, 복호화는 알파벳 순서로 k 번째 앞 문자로 치환하면 된다. 문제에서 $k=1$ 이므로 $L \rightarrow K, O \rightarrow N, P \rightarrow O, V \rightarrow U$ 로 복호화되고, 따라서 평문은 KNOU이다.

연습문제



1. 인증의 개념과 종류를 설명하시오.

정답 및 해설

- 인증의 개념: 어떤 실체가 정말 그 실체가 맞는지 확인하는 과정을 의미한다.
- 인증의 종류: 메시지 인증, 사용자 인증, 출처인증, 장치인증 등

2. 다음 중 메시지 인증에 대한 설명으로 바르지 않은 것은?

- ① 메시지의 내용이 불법적으로 변경되지 않았는지 확인하는 것이다.
- ② 메시지를 받은 사람이 수신된 메시지를 체크할 수 있는 정보가 필요하다.
- ③ 송신자는 메시지 인증 코드를 산출하여 메시지와 함께 전송한다.
- ④ 수신자는 수신한 메시지로부터 송신자와는 다른 키를 이용하여 메시지 인증 코드를 재산출한다.

해설 ④ 수신자는 송신자와 동일한 키로 메시지 인증 코드를 재산출하여 수신한 메시지 인증 코드와 비교해야 한다.

정답 ④

3. 다음 중 메시지 인증 알고리즘은?

- ① HMAC
- ② CBC
- ③ TDEA
- ④ AES

해설 메시지 인증 알고리즘에는 HMAC과 CMAC이 있다. CBC는 CMAC에 사용되는 블록 암호의 사용 모드이다. TDEA와 AES는 블록 암호 알고리즘으로, 그 자체로 메시지 인증 알고리즘이 되지는 못한다.

정답 ①

4. 다음 중 사용자 인증 방식과 거리가 먼 것은?

- ① 비밀번호 방식
- ② 생체인식 방식
- ③ MAC 방식
- ④ 토큰 방식

해설 ③ MAC(메시지 인증 코드)은 메시지 인증을 위한 방식으로, 사용자는 인증할 수 없다.

정답 ③

정답 ④

정답 ③

정답 ①

정답 ②

5. 공격자의 제어하에 있는 호스트를, 피해 호스트가 신뢰하는 호스트로 가장함으로써 피해 호스트로부터 생성되는 정보를 수집하거나 가로채는 방식의 공격은?

① 스푸핑

② 스캐닝

③ DoS

④ DDoS

해설 해당 내용은 스푸핑에 대한 설명이다.

정답 ①

6. 다음 중 네트워크상의 데이터를 도청하는 행위를 의미하는 것은?

① 스푸핑

② 스니핑

③ SQL 인젝션

④ 스캐닝

해설 해당 내용은 스니핑(sniffing)에 대한 설명이다.

정답 ②

7. 특정 서비스나 자원의 가용성을 떨어뜨리는 결과를 초래하는 유형의 공격을 이르는 용어는?

① 피싱

② 스니핑

③ DoS

④ 악성코드

해설 ③ DoS에 대한 설명이다. ①, ②, ④는 가용성을 떨어뜨리는 결과를 초래하지 않을 수도 있다.

정답 ③

8. 다음 설명을 특징으로 갖는 사이버 공격 방식은?

- 특정 서비스나 자원의 가용성을 떨어뜨리는 결과를 초래하는 유형의 공격
- 여러 대의 공격자를 분산적으로 배치해 동시에 공격

① 백도어

② 스푸핑

③ 피싱

④ DDoS

해설 ④ 분산 서비스 거부(DDoS) 공격은 분산된 여러 호스트를 일차적으로 공격하거나 여타의 방법을 이용하여 이들 여러 호스트에 공격 데몬을 설치하고, 공격자는 원격에서 이들 데몬에 특정 공격 목표에 서비스 거부 공격 명령을 내림으로써 다수의 공격 데몬이 동시에 목표에 대한 서비스 거부 공격을 수행하는

방법을 이용한 공격 형태이다.

정답 ④

9. 다음 설명에 해당하는 것은?

불특정 다수를 대상으로 일방적이며 대량으로 전달되는 이메일로, 적은 비용으로 다수의 대상에 상품을 광고하거나 특정 종교를 포교하는 목적으로 이용된다.

① 스팸 메일

② 피싱

③ 스푸핑

④ 스파이웨어

해설 ① 스팸 메일은 불특정 다수를 대상으로 일방적이며 대량으로 전달되는 이메일로, 일반적으로 광고, 홍보, 비방 등의 목적으로 전송된다.

정답 ①

10. 다음 설명에 해당하는 것은?

○○은행에서 온 메일을 열어 보니 내 계좌가 해킹되었다며 빨리 하단의 링크를 클릭하라고 한다. 클릭해 보니 ○○은행 로그인 페이지가 열리는데, 평소와 다르게 ID, 비밀번호와 함께 보안카드 번호를 모두 입력하라고 한다.

① 스팸

② 피싱

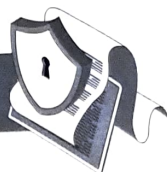
③ 스푸핑

④ 스파이웨어

해설 ② 피싱(phishing)은 유명한 금융기관이나 공신력 있는 업체의 이름을 사칭하여 메일을 보내 수신자가 믿도록 하고, 수신자로부터 개인정보나 금융정보를 얻어 내 범죄수단으로 악용하는 행위이다.

정답 ②

연습문제



1. 서버의 침입 및 정보유출 단계에 대한 설명으로 바른 것은?

- ① 정보획득 단계 - 서버를 통해 다른 시스템을 공격한다.
- ② 권한획득 단계 - 최종적으로 일반 사용자 권한을 획득한다.
- ③ 공격 단계 - 관리자 권한을 이용해서 침입 흔적을 지운다.
- ④ 재침입 단계 - 백도어를 설치한다.

해설 ① 정보획득 단계: 공격대상 시스템에 대한 정보를 획득한다.
 ② 권한획득 단계: 최종적으로 관리자 권한을 획득한다.
 ④ 재침입 단계: 재침입을 대비해서 백도어를 설치한다.

정답 ③

2. 다음 중 설명이 바르지 않은 것은?

- ① 전수 공격 - 사전 파일의 단어를 대입하여 공격한다.
- ② 네트워크 공격 - 스푸핑, 스니핑 등이 해당된다.
- ③ 버퍼 오버플로 공격 - 시스템 오류를 이용하여 공격한다.
- ④ 사회공학적 공격 - 사람을 속여서 민감한 정보를 유출한다.

해설 ① 사전 파일의 단어를 대입하여 공격하는 것은 사전 공격에 해당한다.

정답 ①

3. 다음 중 시스템 오류를 이용한 공격과 거리가 가장 먼 것은?

- ① 스택 오버플로 공격
- ② 레이스 컨디션 공격
- ③ 사전 공격
- ④ 기본 설정 오류를 이용한 공격

해설 ③ 사전 공격은 계정 크랙을 위해 사전 파일의 단어를 대입하여 공격하는 것으로, 시스템 오류와는 거리가 멀다.

정답 ③

4. 다음 중 사람을 속여서 민감한 정보를 유출하게 하는 기술은?

- ① 계정 크랙 공격
- ② 레이스 컨디션 공격
- ③ 사회공학적 공격
- ④ 기본 설정 오류를 이용한 공격

해설 해당 내용은 사회공학적 공격에 대한 설명이다.

정답 ③

5. 서버 보안 관점에서의 계정과 패스워드 관리로 적절하지 않은 것은?

- ① 불필요한 사용자 계정은 삭제한다.
- ② 사전 공격을 막기 위해 유추 가능한 단어를 패스워드로 사용하지 않는다.
- ③ 대소문자, 숫자, 특수문자를 조합하여 패스워드를 만들면 패스워드의 길이가 짧아도 된다.
- ④ 패스워드 실패 횟수가 일정 기준을 넘으면 계정을 잠근다.

해설 ③ 패스워드의 길이가 제한된 경우에는 대소문자, 숫자, 특수문자 등 다양한 종류의 문자를 섞어서 사용하는 것이 패스워드의 복잡도를 증가시키지만, 패스워드 길이 제한이 없다면 긴 패스워드를 사용하는 것이 더 중요하다.

정답 ③

6. 다음 접근제어 정책에 대한 설명 중 올바른 것은?

- ① 강제적 접근제어 - 역할에 따른 접근권한을 부여한다.
- ② 임의적 접근제어 - 객체에 포함된 정보의 비밀성과 이에 대해 주체가 갖는 정형화된 권한에 근거하여 접근권한을 부여한다.
- ③ 역할 기반 접근제어 - 객체 소유자의 자율적 판단에 따라 다른 사용자에게 접근권한을 부여한다.
- ④ 강제적 접근제어 - 객체와 사용자에게 보안등급을 부여하여 사용자가 객체에 접근할 때마다 사전에 규정된 규칙에 근거하여 접근권한을 부여한다.

해설 ① 강제적 접근제어(MAC): 각각의 객체 파일에 비밀등급을 결합시키고 사용자에게는 허가등급을 부여하여, 주체가 객체에 접근할 때마다 사전에 규정된 규칙에 근거하여 접근권한을 부여하는 기법

② 임의적 접근제어(DAC): 관리자 혹은 자원 소유자가 자율적 판단에 따라 보유하고 있는 자원의

접근권한을 다른 사용자에게 부여하는 기법

- ③ 역할 기반 접근제어(RBAC): 권한은 역할과 관련이 있으며, 사용자들은 역할의 한 멤버가 됨으로써 권한을 배정받는 기법

정답 ④

7. 서버 보안 관점에서의 파일 시스템 보호로 적절하지 않은 것은?

- ① 사용자 계정에서 실행권한이 필요 없는 파일은 실행권한을 제거한다.
- ② 불필요한 파일에 설정된 SetUID와 SetGID의 비트를 제거한다.
- ③ xinetd를 이용하여 파일 및 디렉터리가 만들어질 때 접근권한 기본값을 정한다.
- ④ 무결성 점검도구를 이용하여 파일 시스템의 무결성을 검사한다.

해설 ③ umask를 이용하여 파일 및 디렉터리가 만들어질 때 접근권한 기본값을 정한다.

정답 ③

① 기밀성 ② 무결성
③ 유일성 ④ 가용성

정답 ③

- ① 제2계층(데이터 링크 계층) - 전송되는 모든 비트를 전부 암호화하도록 규정
- ② 제3계층(네트워크 계층) - SP3
- ③ 제6계층(프리젠테이션 계층) - 보안 서비스가 제공되지 않는다.
- ④ 제7계층(애플리케이션 계층) - SP4

정답 ②

- ① 인증
- ② 기밀성
- ③ 데이터 무결성
- ④ 부인방지

정답 ②

① 트래픽 패딩

③ 보안 레이블

④ 공증

해설 해당 내용은 트래픽 패딩에 대한 설명이다.

정답 ①

5. 다음 설명에 해당하는 것은?

- IP를 위한 보안 메커니즘이다.
- AH 프로토콜과 ESP 프로토콜이 존재한다.

① SSL

② UDP

③ TCP

④ IPsec

해설 ④ IPsec은 IP를 위한 보안 메커니즘으로, 두 가지 프로토콜인 인증 헤더(AH)와 캡슐화 보안 페이로드(ESP)가 존재한다.

정답 ④

6. 다음 설명에 해당하는 것은?

- 웹 서버와 웹 브라우저 간의 안전한 통신을 위해 Netscape가 개발하였다.
- 애플리케이션 계층의 Telnet, FTP, HTTP 등 프로토콜의 안전성을 보장한다.

① SSL

② UDP

③ TCP

④ IPsec

해설 ① SSL은 웹 서버와 웹 브라우저 간의 안전한 통신을 위해 넷스케이프(Netscape)에 의해 개발된 보안 프로토콜로, 애플리케이션 계층과 TCP 사이에 위치한다.

정답 ①

7. SSL 3.0을 기반으로 한 업그레이드 프로토콜로, 트랜스포트 계층에 적용하는 보안 프로토콜은?

① TCP

② TLS

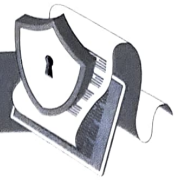
③ UDP

④ ICMP

해설 ② TLS는 Transport Layer Security의 약자로 SSL 3.0을 기반으로 한 업그레이드 프로토콜이다.

정답 ②

연습문제



1. 다음 설명에 가장 부합하는 보안 시스템은?

외부 네트워크에서 유해한 정보가 내부 네트워크로 진입하지 못하도록 차단해 주는 보호정책과 보호장치

- ① 침입탐지 시스템(IDS) ② 침입차단 시스템(firewall)
- ③ 침입방지 시스템(IPS) ④ 가상사설망(VPN)

해설 ② 침입차단 시스템은 외부 네트워크에서 해커나 인증되지 않은 사용자, 혹은 유해한 정보가 내부 네트워크(LAN)로 진입하지 못하도록 차단해 주는 보호정책과 보호장치이다.

정답 ②

2. 다음 중 방화벽의 구성방식과 거리가 먼 것은?

- ① 애플리케이션 게이트웨이 ② 서킷 게이트웨이
- ③ 패킷 필터링 ④ 아날로그 방식

해설 방화벽의 구성방식으로는 패킷 필터링, 서킷 게이트웨이, 애플리케이션 게이트웨이, 하이브리드 방식이 있다.

정답 ④

3. 다음 방화벽의 구축 형태 중 라우터를 이용하지 않는 것은?

- ① 스크리닝 라우터 ② 듀얼홈 호스트
- ③ 스크린 호스트 게이트웨이 ④ 스크린 서브넷 게이트웨이

해설 ② 듀얼홈 호스트는 외부 네트워크와 내부 네트워크가 존재하는 형태로, 두 네트워크 간의 유일한 통로를 구축하여 두 인터페이스에 필터링을 실시한다.

정답 ②

4. 방화벽에 의해 차단되어야 할 패킷이 다른 네트워크 프로토콜에 의해 캡슐화되어 공격에 사용될 때는 방화벽이 이를 차단할 수 없는, 방화벽의 취약점은?

- ① 터널링 공격 ② 중간자 공격
- ③ 무결성 공격 ④ 응용 기반 공격

해설 해당 내용은 터널링 공격에 대한 설명이다.

정답 ①

5. 가상사설망(VPN)에 대한 설명으로 틀린 것은?

- ① 공중망을 이용하여 사설망처럼 직접 운용관리한다.
- ② 저렴한 비용으로 성능향상을 제공한다.
- ③ 방화벽 기반 VPN이 라우터 기반 VPN보다 보안성은 낮지만 성능이 좋다.
- ④ 서비스 품질(QoS)을 제공한다.

해설 ③ 방화벽 기반 VPN은 라우터 기반 VPN보다 보안성은 높지만, 트래픽 증가 시 암호·복호화에 따른 성능저하의 우려가 있다.

정답 ③

6. VPN 구성의 기반기술 중 하나인 터널링 기술에서 사용하는 프로토콜이 아닌 것은?

- ① IPsec
- ② PPTP
- ③ SPD
- ④ L2TP

해설 IPSec, PPTP, L2TP는 VPN 구성의 기반기술 중 하나인 터널링 기술에서 사용하는 프로토콜이다.

정답 ③

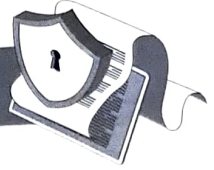
7. 네트워크 접근제어(NAC) 시스템에 대한 설명으로 틀린 것은?

- ① 패치가 제대로 이루어지지 않은 시스템의 네트워크 접근을 통제한다.
- ② 인증을 제대로 거치지 않은 시스템의 네트워크 접근을 통제한다.
- ③ 시스템이 네트워크에 접근을 요청하면 NAC에 등록되어 있는지 우선 확인한다.
- ④ 등록되지 않은 시스템은 네트워크 접근을 절대 불허한다.

해설 ④ 등록되지 않은 시스템이라도 인증된 사용자의 새로운 장치라면 보안 패치나 백신 적용 확인 후 네트워크 접근을 허용한다.

정답 ④

연습문제



1. 침입탐지 시스템의 구성과 설명이 바르게 짝지어진 것은?

- ① 모니터링부 - 정보가공 및 축약
- ② 분석 및 조치부 - 분석 및 침입탐지
- ③ 관리부 - 보고 및 조치
- ④ 모니터링부 - 통제 및 관리, 보안정책 제공

해설 ①, ④ 모니터링부: 정보수집
③ 관리부: 통제 및 관리, 보안정책 제공

정답 ②

2. 일반적으로 무차별 모드를 이용하여 패킷 스니핑을 통해 정보를 수집하는 모니터링 방법은?

- ① 응용 기반 모니터링 방법
- ② 목표 기반 모니터링 방법
- ③ 호스트 기반 모니터링 방법
- ④ 네트워크 기반 모니터링 방법

해설 ④ 네트워크 기반 모니터링 방법은 일반적으로 네트워크 인터페이스 카드의 무차별 모드(promiscuous mode)를 이용하여 패킷 스니핑을 통해 정보를 수집하나, 일부 에이전트는 네트워크 하드웨어 장치의 부가기능으로 수행될 수 있다.

정답 ④

3. 다음 설명에 해당하는 분석방법은?

- 알려진 공격이나 시스템 오용과 관련된 것을 규정한 패턴과의 일치 여부 확인
- 정의된 패턴에 해당되지 않는 공격은 대처 불가

- ① 통계적 분석
- ② 시그니처 분석
- ③ 무결성 분석
- ④ 임의적 분석

해설 ② 시그니처 분석은 알려진 공격이나 시스템 오용과 관련된 것을 규정한 패턴과의 일치 여부를

해설 ③ 침입방지 시스템은 공격탐지 시 자동으로 대응작업을 수행하여 행위를 중지시키는 보안 솔루션으로, 수동적인 침입탐지 시스템과는 대비되어 능동적으로 동작한다.

정답 ③

7. 네트워크 기반 침입방지 시스템(NIPS)에 대한 설명으로 바르지 않은 것은?

- ① 수 Gbps 환경에는 적용할 수 없다.
- ② 비정상 트래픽을 탐지한다.
- ③ 시그니처 또는 비정상행위 탐지를 통해 악의적인 세션을 차단한다.
- ④ 네트워크 라인상에 위치한다.

해설 ① 수 Gbps 환경에는 적용 가능하며, 수십 Gbps 이상의 초고속 환경에서도 적용 가능하도록 성능 개선이 이루어지고 있다.

정답 ①

① 인증 ② 압축
③ 기밀성 ④ 가용성

정답 ④

① 공개키 암호만 이용한다. ② 대칭키 암호만 이용한다.
③ 두 가지 방식을 모두 이용한다. ④ PGP는 기밀성을 보장하지 못한다.

정답 ③

① 16 ② 12
③ 9 ④ 6

정답 ①

- ① 암호화 → 압축 → 서명 → 기수 64 변환
- ② 서명 → 압축 → 암호화 → 기수 64 변환
- ③ 기수 64 변환 → 암호화 → 압축 → 서명
- ④ 기수 64 변환 → 서명 → 압축 → 암호화

해설 인증이 필요하면 평문의 해시코드를 사용하여 서명문 생성 → 그 후, 평문과 서명문 모두를 압축 → 기밀성이 요구되면 압축된 블록을 암호화하고, RSA로 암호화된 세션키 첨부 → 최종적으로 전체 블록을 기수 64 형식으로 변환한 후 수신자에게 전송

정답 ②

5. PGP는 인증기관이 없지만 신뢰를 사용하고 신뢰를 공개키와 연관시키며 신뢰정보를 활용하는 편리한 수단을 제공하는데, 이를 무엇이라 하는가?

- ① 공개키 링 ② 전자서명
③ 마스터 키 ④ 보안 토큰

해설 PGP는 인증기관이 없지만 공개키 링이라는 수단을 사용하여 신뢰를 공개키와 연관시키고 신뢰 정보를 활용하는 편리한 수단을 제공한다.

정답 ①

6. 인터넷 이메일 표준에 보안기능을 강화시킨 것은?

- ① S/MIME ② MIME
③ SMTP ④ RFC 821

해설 이메일 표준은 텍스트 기반의 프로토콜인 RFC 821의 SMTP와 멀티미디어 이메일 프로토콜인 MIME을 거쳐 보안이 강화된 S/MIME이 등장한다.

정답 ①

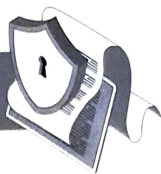
7. S/MIME에 대한 설명으로 바른 것은?

- ① 인터넷 이메일 표준에서 보안기능을 제거한다.
- ② 메시지 암호화는 공개키 방식, 세션키 분배는 대칭키 방식을 이용한다.
- ③ 클리어 서명 데이터는 전자서명만 기수 64로 부호화한다.
- ④ 암호화된 데이터는 서명될 수 있으나, 서명된 데이터는 암호화될 수 없다.

해설 ① 인터넷 이메일 표준에 보안기능을 강화한다.
② 메시지 암호화는 대칭키 방식, 세션키 분배는 공개키 방식을 이용한다.
④ 암호화된 데이터는 서명될 수 있고, 서명된 데이터는 암호화될 수 있다.

정답 ③

연습문제



1. 웹 보안에 대한 설명으로 바르지 않은 것은?

- ① 웹 서비스상에 일어날 수 있는 다양한 공격으로부터 웹 서비스를 지키기 위한 것이다.
- ② HTTP를 이용하는 네트워크 부분은 SSL/TLS를 적용함으로써 해결 가능하다.
- ③ 웹 클라이언트, 웹 서버에 대해서만 별도의 보안기법이 필요하다.
- ④ 웹 보안의 위협 요소로는 SQL injection, XSS 등이 있다.

해설 ③ 웹 클라이언트, 웹 서버 외에 웹 애플리케이션, 데이터베이스 등에도 별도의 보안기법이 필요하다.

정답 ③

2. 다음 중 SQL injection을 방어하는 방법과 거리가 먼 것은?

- ① 웹 애플리케이션의 데이터베이스에 대한 접근권한을 최소화한다.
- ② 프로그램을 만들 때 SQL문을 매개변수화된 쿼리 형태로 작성한다.
- ③ 사용자로 보낼 출력값을 미리 검사한다.
- ④ 사용자의 입력값을 미리 검사한다.

해설 ③ 출력값을 미리 검사하는 것은 XSS를 방어하는 방법에 해당한다.

정답 ③

3. 크로스 사이트 스크립팅(XSS)에 대한 설명으로 바르지 않은 것은?

- ① 이메일이나 웹 페이지에 추가적인 악성 스크립트를 포함시켜 웹 서버에서 악성 스크립트가 실행되게 하는 공격이다.
- ② 궁극적으로 사용자의 정보가 공격자의 사이트로 넘어가게 된다.
- ③ 저장된 XSS는 악성 스크립트를 게시판에 등록하여 사용자가 게시물을 열어 보게 하는 방식이다.
- ④ 반사된 XSS는 악성 스크립트가 포함된 URL을 사용자가 누르게 하는 방식이다.

해설 ① 웹 서버가 아닌 웹 클라이언트에서 악성 스크립트가 실행되게 한다.

정답 ①

4. 다음 웹 보안의 위협 요소와 방어방법 중 잘못된 것은?

- ① SQL injection - 사용자의 입력값을 미리 검사한다.
- ② XSS - 입력값과 출력값을 미리 검사한다.
- ③ 접근제어 실패 - 관리자 페이지에 대한 링크를 만들지 않는다.
- ④ 웹 서버 공격 - 주기적인 웹 서버의 취약점을 점검한다.

해설 ③ 관리자 페이지 자체에 접근권한을 설정해야 한다.

정답 ③

5. RSN에 대한 설명으로 바르지 않은 것은?

- ① IEEE 802.11i 표준이다.
- ② 무선 LAN 환경에서의 보안문제를 해결하는 다양한 방법이 포함된다.
- ③ TKIP는 WPA로 구현된 하드웨어의 펌웨어 업데이트를 위해 사용된다.
- ④ 802.1X는 포트 기반 네트워크 접근제어 표준이다.

해설 ③ TKIP는 임시키 무결성 프로토콜로 WEP로 구현된 하드웨어의 펌웨어 업데이트를 위해 사용된다.

정답 ③

6. WPA에 대한 설명으로 바르지 않은 것은?

- ① WPA는 Wi-Fi Protected Access의 약자이다.
- ② 유선 LAN 보안기능을 제공하는 장비를 인증하기 위해 정의된 규격이다.
- ③ WPA2는 2004년도에 소개되어 2006년도부터 본격적으로 적용되었다.
- ④ WPA3에는 192비트 보안 모드가 추가된다.

해설 ② 유선이 아닌 무선 LAN 보안기능을 제공하는 장비를 인증하기 위해 정의된 규격이다.

정답 ②

7. 다음 모바일 보안 기법과 설명 중 잘못된 것은?

- ① WEP - 현재는 취약성이 드러난다.
- ② CCMP - 기밀성을 위해 카운터 모드와 AES 알고리즘을 이용한다.
- ③ CCMP - 무결성을 위해 CBC-MAC을 이용한다.
- ④ WPA2 - WPA2-Enterprise는 인증 서버 없이 PSK를 사용한다.

해설 ④ WPA2는 WPA2-Enterprise와 WPA2-Personal로 구분되는데, WPA2-Enterprise는 인증 서버를 이용하고, WPA2-Personal은 인증 서버 없이 미리 키를 나누어(PSK) 사용한다.

정답 ④

1. 다음은 범죄 현장에서 발견한 것들이다. 이 중 디지털 포렌식과 거리가 가장 먼 것은?

- ① 전자책 ② 명함집
③ 블랙박스 ④ USB 메모리

해설 명함집은 디지털 매체와 거리가 멀다.

정답 ②

2. 디지털 증거의 특성과 거리가 먼 것은?

- ① 가시성 ② 휘발성
③ 복제용이성 ④ 초국경성

해설 디지털 증거의 특성에는 비가시성, 변조 가능성, 복제용이성, 대규모성, 휘발성 등이 있다.

정답 ①

3. 디지털 증거가 법적 효력을 갖기 위한 속성과 거리가 먼 것은?

- ① 인증성 ② 무결성
③ 신뢰성 ④ 사본성

해설 디지털 증거가 법적 효력을 갖기 위한 속성에는 인증성, 무결성, 신뢰성, 원본성 등이 있다.

정답 ④

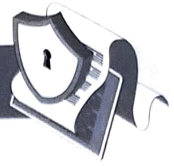
4. 디지털 포렌식의 절차는 사전준비부터 보고서 작성까지 총 여섯 단계이다. 그 사이 네 단계의 순서가 바르게 나열된 것은?

- ① 포장 및 이송 → 증거수집 → 조사분석 → 정밀검토
 ② 증거수집 → 포장 및 이송 → 조사분석 → 정밀검토
 ③ 증거수집 → 정밀검토 → 조사분석 → 포장 및 이송
 ④ 조사분석 → 포장 및 이송 → 정밀검토 → 증거수집

해설 사전준비 → 증거수집 → 포장 및 이송 → 조사분석 → 정밀검토 → 보고서 작성

정답 ②

연습문제



1. 다음 중 대칭키 암호에 대한 설명으로 바른 것은?

- ① 암호화와 복호화에 동일한 키를 이용한다.
- ② 공개키 암호라고도 한다.
- ③ 일반적으로 RSA 알고리즘보다 느리다.
- ④ 키를 안전하게 분배하기가 쉽다.

해설 ② 비밀키 암호라고도 한다.
 ③ 일반적으로 RSA 알고리즘보다 빠르다.
 ④ 키를 안전하게 분배하기 어렵다.

정답 ①

2. 다음 중 의미하는 바가 다른 하나는?

- ① 비밀키 암호
- ② 다중키 암호
- ③ 관용 암호
- ④ 대칭키 암호

해설 ②를 제외하면 모두 대칭키 암호를 의미한다. 대칭키 암호는 단일키 암호이다.

정답 ②

3. 다음 중 블록 암호의 구조에 대한 설명으로 가장 바른 것은?

- ① SPN 구조는 입력받은 블록을 항상 두 개의 블록으로 나누어 처리한다.
- ② 파이스텔 구조는 라운드 함수가 역변환이 가능해야 한다.
- ③ SPN 구조는 병렬화가 쉽지 않다.
- ④ 파이스텔 구조는 DES에 채택된다.

해설 ① 파이스텔 구조는 입력받은 블록을 항상 두 개의 블록으로 나누어 처리한다.
 ② SPN 구조는 라운드 함수가 역변환이 가능해야 한다.
 ③ SPN 구조는 파이스텔 구조보다 병렬화가 쉽다.

정답 ④

4. 다음 블록 암호의 사용 모드 중 같은 평문에 대해서는 같은 암호문이 생성되어 패턴 분석이 가능한 문제가 있는 것은?

- ① 전자 코드 북(ECB) 모드
- ② 암호 블록 연결(CBC) 모드
- ③ 암호 피드백(CFB) 모드
- ④ 출력 피드백(OFB) 모드

해설 ① ECB 모드는 패턴 분석의 문제가 있다.

정답 ①

5. 다음 중 DES를 대신하는 표준 대칭키 암호 시스템으로 미국에서 공표한 것은?

- ① RC5
- ② AES
- ③ SEED
- ④ IDEA

해설 ② 2001년 미국에서는 새로운 표준으로 AES를 공표하였다.

정답 ②

6. 다음 중 AES에서 사용하는 키 크기가 아닌 것은?

- ① 256비트
- ② 192비트
- ③ 128비트
- ④ 64비트

해설 AES에서는 128비트, 192비트, 256비트 중 한 가지를 선택하여 사용한다.

정답 ④

7. 다음 중 대칭키 암호 알고리즘은?

- ① RSA
- ② NTRU
- ③ ARIA
- ④ Lattice

해설 RSA, NTRU, Lattice는 공개키 암호 알고리즘이다.

정답 ③

① 송신자의 개인키 ② 송신자의 공개키
③ 수신자의 개인키 ④ 수신자의 공개키

정답 ④

① 송신자의 개인키 ② 송신자의 공개키
③ 수신자의 개인키 ④ 수신자의 공개키

정답 ③

① 소인수분해 ② 이산대수
③ 전치와 치환 ④ 타원곡선 이산대수

정답 ③

- ① 두 개의 서로 다른 큰 소수 p 와 q 를 생성한다.
- ② $n=(p-1)(q-1)$ 로 계산한다.
- ③ $\phi(n)$ 과 서로소인 수 e 를 임의로 선택한다.
- ④ e 와 n 을 공개키로 둔다.

정답 ②

5. 타원곡선 암호에서 사용되는 타원곡선의 덧셈 연산에 대한 설명으로 바르지 않은 것은?

- ① 타원곡선상의 두 점을 더하는 연산이다.
- ② 덧셈 연산의 결과는 타원곡선상의 점이다.
- ③ 두 점을 잇는 직선과 타원곡선이 만나는 점에서 x 축에 수직인 직선을 이용한다.
- ④ 같은 점끼리 더하지는 못한다.

해설 ④ 같은 점끼리 더할 때는 주어진 점을 지나는 타원곡선의 접선을 이용하여 더한다.

정답 ④

6. 다음 중 공개키 암호 알고리즘은?

- ① CRYPTON ② MISTY
③ RSA ④ FEAL

해설 CRYPTON, MISTY, FEAL은 대칭키 암호 알고리즘이다.

정답 ③

7. 다음 공개키 암호 알고리즘과 기반 문제 중 잘못 짝지어진 것은?

- ① RSA - 이산대수
- ② 타원곡선 암호 - 타원곡선 이산대수
- ③ Lattice - 근접 벡터
- ④ ElGamal - 이산대수

해설 ① RSA는 소인수분해의 어려움에 기반을 두고 있다.

정답 ①

연습문제



1. 해시함수에 대한 설명으로 바르지 않은 것은?

- ① 입력 데이터를 고정된 길이의 해시코드로 대응시키는 함수
- ② 주어진 해시코드에 대해 이 해시코드를 생성하는 데이터를 찾아내는 것은 계산상 실행 불가능하다.
- ③ 해시코드의 길이는 가변적이다.
- ④ 주어진 데이터에 대해 같은 해시코드를 생성하는 또 다른 데이터를 찾아내는 것은 계산상 실행 불가능하다.

해설 해시함수에서 해시코드의 길이는 고정이다.

정답 ③

2. 해시함수 H 의 충돌저항성에 대한 설명으로 바른 것은?

- ① 입력 데이터 D 가 주어졌을 때, $H(D)=H'(D)$ 를 만족하는 다른 해시함수 H' 을 구하는 것이 계산상 실행 불가능하다.
- ② 해시코드 h 가 주어졌을 때, $h=H(D)$ 를 만족하는 입력 데이터 D 를 구하는 것이 계산상 실행 불가능하다.
- ③ 입력 데이터 D 가 주어졌을 때, $H(D)=H(D')$ 을 만족하는 다른 입력 데이터 D' 을 구하는 것이 계산상 실행 불가능하다.
- ④ $H(D)=H(D')$ 을 만족하는 두 입력 데이터 D 와 D' 을 구하는 것이 계산상 실행 불가능하다.

해설 ④번이 충돌저항성에 대한 설명이다. ②는 약한 일방향성, ③은 강한 일방향성에 대한 설명이다.

정답 ④

3. 다음 중 해시 알고리즘에 대한 설명으로 잘못된 것은?

- ① MD4 - 대부분 전용 해시 알고리즘의 기본 모델이 된다.
- ② MD5 - 안전성에 문제가 있어 사용하지 말 것을 권고한다.
- ③ SHA-1 - 128비트의 해시코드를 생성한다.
- ④ SHA-2 - 해시코드의 크기에 따라 네 가지 알고리즘이 있다.

해설

- ② MD5는 충돌저항성과 일방향성에 문제가 있다.
- ③ SHA-1은 160비트의 해시코드를 생성한다.
- ④ SHA-2에는 SHA-224, SHA-256, SHA-384, SHA-512가 있다.

정답 ③

4. 전자서명을 할 때 서명자가 사용하는 키로 바른 것은?

- ① 서명자의 개인키
- ② 서명자의 공개키
- ③ 검증자의 공개키
- ④ 검증자의 개인키

해설

서명자는 자신의 개인키를 사용하여 전자서명을 수행한다.

정답 ①

5. 전자서명이 붙은 메시지를 받은 수신자가 전자서명을 검증할 때 사용하는 키는?

- ① 송신자의 개인키
- ② 송신자의 공개키
- ③ 수신자의 개인키
- ④ 수신자의 공개키

해설

수신자는 전자서명을 한 송신자의 공개키를 사용하여 전자서명을 검증한다.

정답 ②

6. 다음 중 가장 바른 것은?

- ① 메시지 인증은 메시지를 보낸 사람의 신원이 진짜임을 증명한다.
- ② 전자서명은 전달된 메시지의 원래 내용이 변조되지 않았음을 보증한다.
- ③ 메시지 인증은 공개키 암호 방식을 이용해야만 한다.
- ④ 전자서명은 해시함수가 필요하지 않다.

해설

- ① 메시지 인증은 메시지를 보낸 사람의 신원을 증명하지는 못한다.
- ③ 메시지 인증은 대칭키 암호 방식을 이용한다.
- ④ 전자서명은 해시함수가 필요하다.

정답 ②

7. 전자서명표준(DSS)에 해당하는 알고리즘을 모두 고른 것은?

㉠ DSA

㉡ ECDSA

㉢ RSA 전자서명 알고리즘

① ㉠, ㉡

② ㉡, ㉢

③ ㉠, ㉢

④ ㉠, ㉡, ㉢

해설 전자서명표준에는 DSA, ECDSA, RSA 전자서명 알고리즘이 있다.

정답 ④

연습문제



1. 앨리스와 밥이 디피-헬먼 키 교환(DHKE)을 하는데, $p=13$, $g=2$ 이며 앨리스는 임의의 수 s 를 3으로 정하였고 밥이 앨리스에게 보내온 B 는 6일 때, 앨리스와 밥이 공유한 비밀키 k 는?

- ① 1 ② 5 ③ 8 ④ 9

해설 $k = B^s \pmod{p}$ 이므로 $k = 6^3 \pmod{13} = 8$

정답 ③

2. 공개키를 공개하는 다양한 방법 중 가장 안전하며 효율적인 방법은?

- ① 공개선언 ② 신뢰받는 센터
③ 통제된 신뢰받는 센터 ④ 인증기관

해설 ① 가장 안전하지 못하다.
② 공개선언보다는 안전하지만 공개키를 배분할 때 위조의 위험이 있다.
③ 공개키를 분배할 때 통제를 하여 더 높은 수준의 안전성은 확보하지만, 요청이 많아지면 센터에 로드가 많이 걸려 비효율적이다.
④ 가장 안전하며 효율적인 방법이다.

정답 ④

3. 공개키 기반 구조(PKI)에 대한 설명으로 바르지 않은 것은?

- ① 인증서에 대한 생성·분배·인증·폐지를 관리하는 체계이다.
② X.509 디렉터리 서비스를 제공한다.
③ 공개키 암호를 통해 암호화 및 전자서명을 제공하는 복합적인 보안 시스템
④ 응용 분야 중 병원에서의 의무기록에 대한 서명이 있다.

해설 ② X.509에 기초한 인증서를 생성한다. 디렉터리 서비스는 X.509가 아닌 X.500이다.

정답 ②

4. X.509에서 정의하는 인증서에 포함되는 내용과 거리가 먼 것은?

- ① 인증서의 유효기간 ② 소유자의 공개키 사본
③ 수령인의 개인키 사본 ④ 발급기관의 전자서명

해설 ③ 개인키는 절대로 남에게 알려지면 안 되는 것이므로 인증서에 포함되어서는 안 된다.

정답 ③

5. 공개키 기반 구조에서 제공되는 보안 서비스를 모두 고른 것은?

- | | | |
|-------|--------|--------|
| ㉠ 기밀성 | ㉡ 무결성 | ㉢ 접근제어 |
| ㉣ 인증 | ㉤ 부인방지 | |

① ㉠, ㉣

② ㉠, ㉡, ㉣

③ ㉠, ㉡, ㉣, ㉤

④ ㉠, ㉡, ㉢, ㉣, ㉤

해설 PKI는 기밀성, 무결성, 접근제어, 인증, 부인방지 서비스를 제공한다.

정답 ④

6. 다음 중 공개키 기반 구조의 구성요소에 해당하지 않는 것은?

① 등록기관

② 인증기관

③ 디렉터리

④ 제공자

해설 공개키 기반 구조(PKI)를 구성하는 요소로는 인증서를 발행하고 취소하는 인증기관, 인증서 등록 및 사용자 신원확인을 대행하는 등록기관, 인증서 및 인증서 취소목록을 저장하고 사용자에게 서비스하는 디렉터리, 그리고 인증서를 신청하고 사용하는 사용자가 있다.

정답 ④

7. 다음 공개키 기반 구조의 구성요소와 설명 중 잘못된 것은?

① 인증기관 - 인증서 발급

② 등록기관 - 사용자들의 신원확인

③ 디렉터리 - 사용자의 전자서명 저장

④ 사용자 - 인증서 요청 및 획득

해설 ③ 디렉터리는 인증서 및 인증서 취소목록을 저장하고 사용자에게 서비스한다. 사용자의 전자서명을 저장하지는 않는다.

정답 ③